Análise de arquivo suspeito

Share

codigo.c

C

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Checking whether the file's contents are already available

Vou começar lendo o arquivo para analisá-lo.

Read 2 files, ran a command

Li o arquivo inteiro (878 linhas de C para Linux). **É malware**: um backdoor. Segue a análise.

1. Visão geral. O código junta coisas que quase nunca aparecem num software legítimo: captura de pacotes em socket bruto com filtro BPF no kernel, pseudo-terminal, shell remoto, cifragem RC4 e manipulação do nome do processo. Não há interface, log, configuração nem função útil ao usuário.

2. Furtividade na inicialização. Só executa como root e usa um arquivo-marcador para não duplicar instâncias. Reescreve a data do próprio arquivo para um timestamp antigo, o que dificulta a perícia. Copia-se para `/dev/shm` (memória) com nome inócuo, roda dali, apaga a cópia e vira daemon.

3. Disfarce. Sobrescreve o nome do processo para imitar serviços legítimos do sistema, sorteando entre udevd, mingetty, auditd, dbus-daemon, systemd-journald e outros. Comandos, caminhos e senhas ficam como arrays de bytes, para escapar de detecção por strings.

4. Canal de comando passivo. Não abre porta de escuta. Fica observando o tráfego TCP, UDP e ICMP em nível de pacote bruto, à espera de um "pacote mágico" autenticado por senha. Por isso não aparece como serviço em escuta e pode receber o gatilho até em portas que o firewall do host bloqueia.

5. Acesso do operador. Ao receber um gatilho válido, ele se desvincula, troca o nome de novo e entrega um shell ao atacante. O modo depende da senha: conexão reversa para um endereço indicado, ou porta alta com regras de iptables que redirecionam o tráfego do IP do atacante. Há também um modo de sondagem que só envia um datagrama UDP.

6. Sessão do shell. Roda `/bin/sh` com histórico desativado (inclusive o do MySQL) e tráfego cifrado com RC4, o que dificulta a perícia e a inspeção de rede.

Veredito

Malware. É um backdoor/RAT para Linux, que corresponde de forma muito próxima ao código-fonte público da família **BPFDoor**. Fornecedores de segurança associam essa família ao grupo Red Menshen. Minha confiança é alta, porque nenhuma função do código tem propósito legítimo e todas servem a acesso remoto oculto e evasão. A análise foi estática: li o código, mas não compilei nem executei.

Se você encontrou esse arquivo em algum sistema, trate como possível comprometimento:

- Isole o host e preserve evidências (memória e disco) antes de limpar. A presença do código-fonte pode indicar que alguém o compilou ali.
- Procure por `/var/run/haldrund.pid` e `/dev/shm/kdmtmpflush`.
- Procure por processos com nome de daemon do sistema que mantenham um socket de pacotes aberto (`ss -0pb` ajuda) ou que executem a partir de `/dev/shm`.
- Procure por regras NAT de `REDIRECT` temporárias para portas altas.

Paro neste nível de detalhe: não vou explicar o funcionamento linha a linha nem ajudar a compilar, modificar ou implantar o código. Posso ajudar com detecção, caça de ameaças e resposta a incidentes. Você encontrou esse arquivo em algum sistema ou está triando amostras?

Qual é a categoria principal deste malware?

Confirmando o mapeamento de técnicas MITRE do backdoor ▸

A categoria principal é **backdoor** (porta dos fundos), mais especificamente um **backdoor passivo para Linux**, que funciona como um RAT (ferramenta de acesso remoto) furtivo.

A função central do código é dar a um operador remoto um shell interativo no sistema, sem autorização e sem ficar visível. Ele faz isso esperando um pacote especial em vez de abrir uma porta de escuta, o que o torna "passivo".

Ele não se encaixa em outras categorias comuns:

- **Ransomware, stealer ou miner:** não há criptografia de arquivos, coleta de credenciais ou mineração. Ele só abre o acesso, e o que o atacante faz depois fica por conta dele.
- **Worm ou vírus:** não se replica nem se propaga para outros sistemas.
- **Rootkit:** tem comportamento furtivo (disfarça o processo, altera datas, desativa histórico), mas não modifica o kernel nem esconde objetos do sistema. A furtividade é um recurso de apoio, não a função principal.

Como referência no MITRE ATT&CK, as técnicas mais características são o sinal de tráfego por filtro de socket (T1205.002), o mascaramento de processos (T1036), a alteração de timestamps (T1070.006), a desativação do histórico de comandos (T1562.003) e o canal cifrado com cifra simétrica (T1573.001).

